

Received 25 February 2025, accepted 15 March 2025, date of publication 18 March 2025, date of current version 27 March 2025.

Digital Object Identifier 10.1109/ACCESS.2025.3552523

APPLIED RESEARCH

A Review of Tactics, Techniques, and Procedures (TTPs) of MITRE Framework for Business Email Compromise (BEC) Attacks

SEBASTIEN KANJ BONHARD^{1,2}, PAU GARCIA VILLALTA²,
ORIO ROSÉS², AND JOSEP PEGUEROLES¹, (Member, IEEE)

¹Department of Telematics, Universitat Politècnica de Catalunya, 08034 Barcelona, Spain

²INCIDE Digital Data S.L., 08021 Barcelona, Spain

Corresponding author: Sebastien Kanj Bonhard (sebastien.kanj@upc.edu)

This work was supported in part by the Ministerio de Ciencia y Educación of Spain (MICINN) through the Project TCO-RISEBLOCK under Grant PID2019-110224RB-I00, in part by the Generalitat de Catalunya under Grant 2021 DI 92, and in part by the INCIDE Digital Data S.L.

ABSTRACT The MITRE ATT&CK (Registered trademark) framework is a globally recognized repository of adversarial Tactics, Techniques, and Procedures (TTPs) based on real-world cyber threats. It provides a model for analyzing attack behaviors and enhancing incident attribution. Business Email Compromise (BEC) frauds, a growing cyber threat, exploit email communications for financial gain. However, the MITRE framework is not widely used for BEC, as no custom matrix has been developed specifically for these attacks. This study maps the TTPs used by BEC Threat Actors (TA) within the MITRE ATT&CK framework. The methodology included a review of academic literature, Cyber Threat Intelligence (CTI) reports, and real-world incident response data from INCIDE Digital Data S.L. A total of 10 tactics, 34 techniques, and 46 sub-techniques were identified, with 5 new sub-techniques proposed to address gaps, particularly in mailbox manipulation and defense evasion. Additionally, Privilege Escalation, Lateral Movement, and Credential Access tactics were merged due to overlapping techniques, while the Execution tactic was excluded as it is not central to BEC attacks. To demonstrate the utility of the framework, we characterized two real-world TAs: Cosmic Lynx, a sophisticated actor targeting multinational organizations, and Chiffon Herring, a smaller-scale attacker employing simpler methods. These case studies highlight the framework's adaptability for analyzing diverse TA profiles and its potential to support improved incident attribution, detection, and prevention strategies.

INDEX TERMS Business email compromise (BEC), DFIR, MITRE, procedures, tactics, techniques, TTP.

I. INTRODUCTION

The MITRE Corporation [1], a prominent not-for-profit organization, has made significant contributions to cybersecurity through the development of the MITRE ATT&CK[®] framework. This comprehensive framework serves as a foundational tool for cybersecurity professionals, providing a systematic methodology for categorizing and analyzing the Tactics, Techniques, and Procedures (TTPs) employed

by Threat Actors (TA) during cyber incidents. The MITRE ATT&CK matrix [2], at the core of this framework, offers a detailed and structured taxonomy that facilitates the characterization of cybersecurity threats. By dissecting and mapping the specific behaviors observed during an incident to particular TAs, the ATT&CK framework plays a crucial role in the attribution of cyberattacks, thereby supporting more effective incident response and prevention strategies. The framework's organization into tactics (representing the goals or intentions behind a phase of an attack), techniques (the methods used to achieve these goals), and sub-techniques

The associate editor coordinating the review of this manuscript and approving it for publication was Abdel-Hamid Soliman¹.

(specific, refined actions within broader techniques) allows for a nuanced understanding of the diverse strategies employed by adversaries.

One of the most significant and growing threats in the cybersecurity landscape is Business Email Compromise (BEC). BEC frauds represent a complex and evolving category of cyber incidents, characterized by malicious manipulation of email conversations to achieve financial gain [3]. According to the Anti-Phishing Working Group (APWG), during the third quarter of 2024, gift card scams were the most common type of scam, accounting for 40.4 percent of all reported cases, followed by advance fee fraud scams at 29.8 percent. Meanwhile, the average amount requested in wire transfer BEC attacks was \$67,145, reflecting a 25 percent decrease from Q2's average of \$89,520. Despite this decline in requested amounts, wire transfer BEC attacks remain a significant threat, although their volume also dropped by 25.5 percent compared to the previous quarter [4]. The FBI's Internet Crime Complaint Center (IC3) reported 21,489 BEC complaints in 2023, with adjusted losses exceeding \$2.9 billion, making it the second-costliest type of cybercrime tracked by the IC3. Although investment fraud incurred the highest financial losses at \$4.57 billion, the scale and financial impact of BEC attacks demonstrate their ongoing threat. Notably, tech support scams were ranked third, while demographic differences in victimization highlighted that BEC and investment fraud predominantly affected individuals aged 30 to 49 years old [5]. The growing sophistication and evolving nature of BEC frauds, combined with their potential for substantial financial and operational impact, underscore their critical status as a global cybersecurity challenge. These schemes typically involve advanced tactics, such as wire transfer manipulation, leading to fraudulent transactions or unauthorized fund transfers. Robust countermeasures and enhanced threat intelligence are essential to mitigate these risks effectively.

BEC frauds can be categorized based on factors such as the impersonated individual, the targeted victim, and the specific strategy employed by the attacker [6]. Understanding these typologies helps organizations implement tailored countermeasures effectively. Numerous studies have highlighted the techniques commonly used in BEC frauds, including phishing [7], [8], spoofing [9], [10], social engineering [11], [12], stealer malware [13], [14], and document manipulation [6]. These techniques underscore the multifaceted nature of BEC frauds and the importance of robust cybersecurity measures to mitigate these risks [15], [16].

Despite the extensive documentation of individual techniques used in BEC frauds, the application of the MITRE ATT&CK framework for characterizing and attributing these attacks, while not limited, has not seen widespread adoption. The framework itself is standardized and has been extensively used to analyze and attribute other types of cyberattacks, such as ransomware [17], data exfiltration [18] or Smart Grid systems [19]. However, no comprehensive research has been conducted to specifically identify and select the tactics

and techniques within the framework that are most relevant and commonly applied to BEC frauds. As a result, the unique aspects of BEC-related tactics and techniques are not fully addressed. Although Cyber Threat Intelligence (CTI) reports on BEC-focused TA, such as Cosmic Lynx [20], Gold Skyline [21], and Gold Galleon [22], have identified various techniques employed by these groups, the lack of targeted research and selection of relevant TTPs complicates the effective attribution of incidents and comparison of different TA within the standardized MITRE ATT&CK matrix.

In this research, we aim to address the existing gap in systematically analyzing the techniques employed by Threat Actors (TA) in Business Email Compromise (BEC) frauds. To achieve this, we undertook the following actions:

- 1) Conducted a comprehensive examination of techniques used in BEC attacks, focusing on their impact on email security and the progression of such attacks.
- 2) Systematically mapped these techniques to the MITRE ATT&CK framework, providing a structured and standardized representation of BEC-specific tactics and techniques.
- 3) Analyzed and adapted the MITRE ATT&CK framework to better represent the unique characteristics of BEC frauds, ensuring its applicability to this specific threat landscape.
- 4) Applied the resultant matrix to demonstrate its capability to characterize real-world TAs effectively.

The following sections provide a detailed outline of the study's content and findings: **Related Work** reviews previous studies on BEC techniques and highlights the limitations of existing approaches in mapping these techniques to a standardized threat intelligence framework. **Methodology** describes the systematic process employed to identify and categorize BEC-specific TTPs, utilizing insights from academic literature, industry reports, and real incident data. **Results** presents the identified TTPs and introduces new sub-techniques not previously documented in the MITRE framework, supported by graphical representations in matrix format. **Discussion of the Results** examines the practical implications of these findings, including the characterization of a TA to illustrate the utility of the resultant matrix in analyzing and attributing BEC incidents. Finally, **Conclusion and Future Work** summarizes the contributions of this study and proposes directions for further research, with a particular focus on refining threat intelligence for BEC-specific threats.

II. RELATED WORK

This section provides a comparative analysis of our findings in the context of existing studies on BEC frauds, highlighting similarities, differences, and the broader implications of our approach. Previous research has predominantly focused on individual BEC techniques, such as phishing, spoofing, social engineering, and malware. For instance, Papathanasiou et al. [15] and Bakari and Shukla [23] examine these techniques with an emphasis on email characteristics and common attack

vectors. Other studies, such as those by Ogwo-Ude [16] and Al-Musib et al. [6], delve into the methodologies employed by TAs, while Mansfield-Devine [3], Kolouch [24], and Zweighaft [25] explore the economic impact and evolution of BEC frauds on businesses. Although these studies provide valuable insights, they do not employ the internationally recognized MITRE ATT&CK framework, which limits their ability to systematically map and categorize BEC-related tactics and techniques.

Moreover, while some studies propose countermeasures to mitigate BEC attacks, as seen in the work of Bakari and Shukla [23], their approaches are often limited by a lack of integration with real-world incident data. Our study distinguishes itself by combining insights from academic literature, industry Cyber Threat Intelligence (CTI) reports, and real-case incident response cases. This integration offers a holistic and practical view of BEC frauds, enabling a deeper understanding of the tactics and techniques employed by TAs. By uniting these diverse data sources, our research provides a unique and comprehensive perspective that supports more effective threat analysis and mitigation strategies.

The Cyber Kill Chain and the Diamond Model are two well-established frameworks in threat intelligence research that offer valuable methods for analyzing cyber threats. The Cyber Kill Chain, describes the stages of a cyberattack from initial reconnaissance to exploitation and actions on objectives [26]. It is particularly effective in understanding the sequential phases of attacks and informing defense strategies by breaking the chain at any stage. Similarly, the Diamond Model of Intrusion Analysis emphasizes the relationships between adversaries, capabilities, infrastructure, and victims, offering a structured way to attribute attacks and analyze adversarial behavior [27].

While both the Cyber Kill Chain and the Diamond Model provide useful perspectives, the MITRE ATT&CK framework offers a more granular and comprehensive taxonomy for categorizing specific TTPs across various TAs. Unlike the linear perspective of the Cyber Kill Chain, ATT&CK captures a broader range of techniques that can occur at any stage of an attack, making it particularly well-suited for characterizing the diverse and iterative methods used in BEC frauds. Furthermore, while the Diamond Model excels in high-level adversary analysis, ATT&CK's detailed matrix facilitates practical application, such as mapping observed behaviors to specific techniques and sub-techniques [28].

In addition to discussing these frameworks, it is important to highlight that our methodology aligns with established approaches in other cybersecurity domains, such as ransomware, data exfiltration, and smart grid systems, where the MITRE ATT&CK framework has been applied to characterize cyber threats. Studies by Raj et al. [17], Mundt and Baier [18], and Izzuddin and Lim [19] demonstrate successful applications of the MITRE framework in these areas. By adopting a similar methodology for BEC frauds, our

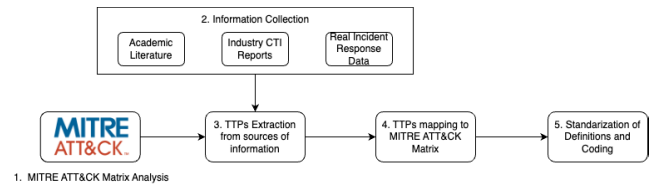


FIGURE 1. Proposed methodology for BEC TTPs review.

work contributes to the standardization of threat intelligence practices across diverse cyber threat landscapes, ensuring consistency and coherence in threat characterization.

While phishing, spoofing, and social engineering techniques have been extensively studied within the BEC context, further investigation reveals a need to understand additional tactics related to detection evasion, persistence, and preparatory stages of attacks. These aspects shed light on how TAs manipulate trusted infrastructures and email systems to bypass security controls. Addressing these dimensions offers a more comprehensive understanding of the full lifecycle of BEC attacks, encompassing the initial setup, preparation phases, and tactics used to maintain access and evade detection.

In summary, while existing research provides insights into individual BEC techniques, none systematically apply the MITRE ATT&CK framework or integrate insights from the Cyber Kill Chain and Diamond Model in a unified approach. Our findings expand the scope of BEC research by delivering a robust framework for categorizing BEC-related tactics and techniques, while also aligning with methodologies used in other cyber threat areas such as ransomware, data exfiltration, and smart grid systems. This comparative analysis underscores the novelty and practicality of our approach, particularly in the areas of detection evasion, persistence, and the preparatory phases of BEC frauds.

III. METHODOLOGY

To achieve the goals of this investigation, the following methodology was designed to systematically review and map the TTPs used by TAs in BEC frauds within the MITRE ATT&CK framework. By integrating data from diverse information sources—academic literature, industry CTI reports, and real-world incident response data from INCIDE Digital Data S.L.—we aim to provide a comprehensive analysis of BEC-specific TTPs. This approach involves identifying, mapping, and standardizing BEC-related tactics and techniques within the ATT&CK matrix to ensure an accurate representation of BEC activities. The following subsections detail each step of the methodology, from initial analysis to final standardization. An overview of the methodology is presented in Figure 1.

A. MITRE ATT&CK MATRIX ANALYSIS

The MITRE ATT&CK framework serves as a globally recognized repository that catalogues adversarial TTPs based on real-world cyber threat observations. It provides

a systematic framework for analyzing attack stages and understanding adversarial tactics. The ATT&CK matrix categorizes tactics as the overarching goals of attackers, while techniques represent the specific methods employed to achieve these objectives, with additional sub-techniques refining these methods further. This phase of the study focuses on identifying TTPs within the ATT&CK matrix that are most applicable to BEC frauds, emphasizing unique aspects of email compromise attacks. These TTPs are then selected as an initial subset specifically relevant to BEC frauds and email infrastructures. The selection process prioritized techniques related to the email environment, email elements, and other infrastructure components commonly exploited in BEC frauds to ensure a targeted and accurate mapping within the framework.

B. INFORMATION COLLECTION

One of the main challenges in studying BEC frauds is the absence of publicly available large-scale datasets or comprehensive disclosed reports. Unlike other cyber threats such as malware or ransomware, BEC fraud primarily relies on social engineering tactics, which are often underreported or documented in a fragmented manner. Due to this limitation, research in this area must rely on a combination of different data sources.

The second phase involves gathering and analyzing data from various sources to identify relevant TTPs in BEC frauds. When a technique was identified in the sources, it was taken into consideration and assessed for its applicability within the context of BEC attacks, ensuring a comprehensive mapping of tactics, techniques, and sub-techniques. The sources used in the investigation were:

- 1) **Academic Literature:** A comprehensive review of academic papers on BEC frauds was conducted, focusing on phishing, spoofing, document manipulation, malware, and other email-based attack vectors. This literature provided a theoretical foundation for understanding TAs' techniques and behaviors in BEC incidents. Insights from academic studies were compared with findings from industry reports to ensure consistency in identifying relevant tactics and techniques.
- 2) **Industry Cyber Threat Intelligence (CTI) Reports:** CTI reports from leading cybersecurity firms were analyzed to gain insights into the latest tactics and techniques used by TAs in BEC frauds. These reports offer real-time data and practical examples from recent BEC campaigns, complementing the theoretical perspectives from academia and facilitating a cross-validation process.
- 3) **Real Incident Response Data:** Data from BEC cases handled by INCIDE Digital Data S.L. [29] provided firsthand examples of TTPs used by TAs. This real-world data, derived from actual incidents, included detailed attack paths and behaviors observed in BEC

response scenarios, offering a unique perspective on TTP application.

C. TTP EXTRACTION

The collected data was meticulously analyzed to identify relevant TTPs, focusing on tactics, techniques, and sub-techniques that might not be fully covered or might be named differently across sources. This analysis included:

- 1) **Identification of Tactics:** Tactics were identified by analyzing the intent of the attacker and the objectives of each attack phase. Each tactic represents a high-level goal within the BEC attack lifecycle, with consistency achieved by harmonizing terminology across different sources and aligning with the MITRE framework.
- 2) **Identification of Techniques:** Techniques, representing specific methods used to achieve each tactic, were extracted from the data. Some techniques were clearly defined, while others required interpretation due to variations in naming or categorization across sources.
- 3) **Identification of Sub-Techniques:** Variations of techniques, or sub-techniques, were identified where applicable. These sub-techniques were distinguished by their unique characteristics and specific relevance to BEC frauds.

D. MAPPING TO THE MITRE ATT&CK MATRIX

After identifying relevant TTPs, each element was mapped to the MITRE ATT&CK framework through a structured process that emphasized consistency and alignment with the framework's classification standards:

- 1) **Phase Alignment:** Each tactic, technique, and sub-technique was aligned with the appropriate phase of the ATT&CK matrix based on its functional role in the attack lifecycle, for example, the registration of a typosquatting domain by an attacker is classified under the Resource Development (TA0042) phase. When a TTP could logically fit into multiple phases, the primary intent of the activity as described in the sources was used to determine the most suitable phase.
- 2) **Objective Definition:** The underlying objectives of each TTP were explicitly defined to ensure a clear understanding of its purpose within the BEC attack context. This step also helped to resolve ambiguities when a TTP description overlapped with multiple tactics, ensuring that classification reflected its dominant operational role.
- 3) **Technique Matching:** Identified techniques were compared against existing entries in the ATT&CK matrix to find the corresponding match. For example, the registration of a new device as a multi-factor authentication method is mapped to the Modify Authentication Process (T1556) technique under the Persistence (TA0003) tactic. For techniques with multiple names across sources, their functional intent and observed use cases were prioritized to determine the

most appropriate ATT&CK-defined technique. Where overlaps occurred, all relevant techniques were noted for transparency.

- 4) **Sub-Technique Selection:** Sub-techniques were mapped to the ATT&CK matrix by analyzing their specific implementation details and aligning them with the most accurate existing sub-technique. For example, when TAs send malicious links to targeted accounts to harvest credentials and gain unauthorized access, this activity aligns with the Initial Access (TA0001) tactic, the Phishing (T1566) technique, and specifically the Spearphishing Link (T1566.002) sub-technique. If no direct match was available, new sub-techniques were proposed, ensuring alignment with the overarching logic and structure of the ATT&CK framework.
- 5) **Redundancy and Uniqueness Analysis:** Each mapped TTP was reviewed to eliminate redundancies and ensure uniqueness. When multiple sources described similar TTPs with varying levels of detail, the most comprehensive description was used, and its classification was aligned with the framework's taxonomy. This ensured that every mapped TTP served a distinct and well-defined purpose.

E. STANDARDIZATION OF DEFINITIONS AND CODING

In the final phase, TTP definitions were standardized within the MITRE ATT&CK framework:

- 1) **Assignment of Identifiers:** Each tactic, technique, and sub-technique was assigned a corresponding identifier within the ATT&CK framework (e.g., TA#### for tactics, T#### for techniques, and T####.### for sub-techniques). For proposed sub-techniques, the identifier of the parent technique was used followed by “.XX” (e.g., T####.XX).
- 2) **Provision of Descriptions:** Clear, concise descriptions were provided for each tactic, technique, and sub-technique to specify their roles in BEC incidents.
- 3) **Citation of References:** Each technique and sub-technique was supported with references from the information sources. Where sub-techniques were grouped under a single reference, either the entire group was covered or individual references were cited as needed.
- 4) **Development of a Schematic Representation:** A visual schematic of the mapped matrix was developed, offering an overview of BEC-specific TTPs and their placement within the broader ATT&CK framework.

IV. RESULTS

In this section, we present the findings from our analysis, detailing the identified tactics, techniques, and sub-techniques specific to BEC frauds. Each entry is accompanied by a concise definition and references to the information sources. Additionally, a schematic representation

of the resultant matrix is shown in Figure 2, located at the end of this section.

Building on the foundation established in the methodology, the analysis began with the selection of techniques related to information gathering and cloud or email infrastructures. These areas were prioritized due to their direct relevance to the objectives and behaviors of TAs in BEC frauds. The data collection process incorporated more than 54 sources, including 24 academic sources, 10 industry CTI reports, and real-world insights from over 20 incident response cases. This diverse range of information sources enabled a comprehensive refinement of the preselected techniques, ensuring their applicability to the BEC threat landscape.

The section also introduces five proposed sub-techniques that address gaps in the current MITRE ATT&CK framework and provides an explanation for the merging of three tactics—Privilege Escalation, Lateral Movement, and Credential Access—due to overlapping objectives and methods. Additionally, the Execution tactic was excluded as it does not align with the typical activities involved in BEC frauds, further refining the matrix to accurately represent this specific threat landscape.

In the following subsections, the resulting tactics, techniques, and sub-techniques related to BEC frauds are presented. The tactics identified include: (A) **Reconnaissance**, (B) **Resource Development**, (C) **Initial Access**, (D) **Persistence**, (E) **Defense Evasion**, (F) **Discovery**, (G) **Privilege Escalation / Lateral Movement / Credential Access**, (H) **Collection**, (I) **Exfiltration**, and (J) **Impact**.

A. RECONNAISSANCE (TA0043)

Reconnaissance is the phase where TA meticulously select their targets, setting the stage for subsequent malicious activities. During this tactic, various techniques are employed to gather critical intelligence about the victim organization and identify potential vulnerabilities. The following techniques are commonly observed in BEC incidents:

- 1) **Active Scanning (T1595):** Attackers conduct scans of public IP addresses on the Internet to identify potential vulnerabilities or misconfigurations related to mail services. Sub-techniques include:
 - a) **Vulnerability Scanning (T1595.002):** This involves scanning the Internet for exposed on-premise mail servers with vulnerabilities or misconfigurations that could be exploited to gain unauthorized access [30]. Identifying and exploiting these weaknesses allows attackers to establish a foothold within the victim organization's email ecosystem.
- 2) **Victim Organization Information (T1591):** This overarching technique includes various sub-techniques for gathering intelligence about the target organization, which is crucial for identifying potential targets and refining attack strategies in BEC frauds [16]. Sub-techniques include:

- a) **Business Relationships (T1591.002):** TA use open-source intelligence (OSINT) to gather information about the business relationships and partnerships of the victim organization. By identifying key suppliers, vendors, and business partners, attackers can tailor their BEC schemes to exploit existing relationships, increasing the likelihood of success [31].
 - b) **Identify Roles (T1591.004):** This technique involves identifying key individuals within the victim organization, particularly those in executive or financial roles [31]. By targeting decision-makers and personnel responsible for financial transactions, TA can focus their efforts on individuals likely to yield significant financial returns.
- 3) **Brute Force (T1110):** The attackers can use credentials acquired from different sources to test their validity and gain access to accounts.
- a) **Credential Stuffing (T1110.004):** In this technique, TA leverage compromised credentials obtained from recent data breaches or botnet databases to attempt unauthorized access to the victim organization's infrastructure [13]. Unlike other selection criteria, credential stuffing indiscriminately targets organizations based on the availability of credentials, highlighting the pervasive nature of this threat vector in BEC incidents.
- ### B. RESOURCE DEVELOPMENT (TA0042)
- Resource Development is the phase where TA invest time and effort into establishing the necessary infrastructure and capabilities to execute fraudulent activities effectively. This tactic encompasses a range of techniques aimed at acquiring, accessing, and developing resources essential for orchestrating BEC frauds [15]. The following techniques are commonly observed within the Resource Development tactic:
- 1) **Acquire Infrastructure (T1583):** This technique involves acquiring various infrastructure components crucial for executing impersonation attacks. Sub-techniques include:
 - a) **Domain (T1583.001):** TA register counterfeit or typo-squatted domains to mimic legitimate entities, facilitating email impersonation and deception [15].
 - b) **Server (T1583.004):** Attackers procure servers dedicated to sending and receiving fraudulent emails, enabling the orchestration of BEC campaigns [32].
 - c) **Botnet (T1583.005):** TA may acquire access to a botnet to obtain stolen credentials indexed in the database or to utilize infected devices as the origin for sending their fraudulent emails [13].
 - d) **Web Services (T1583.006):** Attackers acquire and create illegitimate web pages containing fraudulent content designed to deceive users and elicit sensitive information. These pages may be utilized in subsequent phishing campaigns to trick users into divulging credentials or one-time passwords (OTPs) for 2FA authentication [8].
 - 2) **Acquire Access (T1650):** This technique involves obtaining unauthorized access to email servers or accounts, often through the purchase of access credentials from Initial Access Brokers (IAB) [13].
 - 3) **Establish Accounts (T1585):** Attackers create accounts on various services to support their malicious activities. Sub-techniques include:
 - a) **Email Accounts (T1585.002):** TA may register email addresses through cloud mail service providers to impersonate legitimate entities. This sub-technique involves creating deceptive email addresses, often exploiting variations or alterations of legitimate domains [3].
 - 4) **Compromise Accounts (T1586):** TA compromise accounts, typically through social engineering or credential theft, to facilitate their BEC campaigns. Sub-techniques include:
 - a) **Social Media Accounts (T1586.001):** Attackers may compromise social media accounts to gather intelligence, execute lateral movement within the target organization, or employ social engineering tactics [33].
 - b) **Email Accounts (T1586.002):** TA may compromise email accounts of organizations or individuals to launch phishing campaigns [34].
 - 5) **Develop Capabilities (T1587):** This technique involves the development of customized tools and capabilities tailored to the specific requirements of BEC frauds. Sub-techniques include:
 - a) **Malware (T1587.001):** TA develop malware, such as stealers, to harvest credentials, session tokens, or other sensitive information from compromised systems. This malware may also target mobile devices to bypass two-factor authentication (2FA) mechanisms [3].
 - 6) **Stage Capabilities (T1608):** Attackers leverage acquired capabilities to enhance their operations within the compromised environment. Sub-techniques include:
 - a) **Link Target (T1608.005):** Prior to executing a phishing attack, adversaries must establish the resources necessary for the malicious link, which could include creating a webpage or setting up a server to host malicious content [8].
- ### C. INITIAL ACCESS (TA0001)
- Initial Access encompasses techniques aimed at obtaining unauthorized access to victims' email accounts or mail servers, serving as a pivotal first step in the BEC attack

lifecycle. The following techniques are commonly employed by TA to gain initial access:

- 1) **Exploit Public-Facing Mail Servers (T1190)**: TA exploit vulnerabilities or misconfigurations in public-facing mail servers to gain unauthorized access and infiltrate targeted mailboxes [30].
- 2) **Valid Accounts (T1078)**: Attackers utilize valid accounts obtained through various means, including IAB, data leaks, malware stealer or botnets, to access user accounts [13]. Sub-techniques include:
 - a) **Domain Accounts (T1078.002)**: TA leverage domain accounts synchronized with mail services to gain access to user mailboxes.
 - b) **Cloud Accounts (T1078.004)**: Attackers utilize accounts associated with cloud email services to gain unauthorized access to user accounts.
- 3) **Phishing (T1566)**: TA employ phishing techniques to deceive victims and obtain access to their accounts. Sub-techniques include [24]:
 - a) **Spearphishing Attachment (T1566.001)**: Attackers send emails with malicious attachments designed to steal credentials or tokens upon execution.
 - b) **Spearphishing Link (T1566.002)**: Attackers send emails containing deceptive links that prompt users to enter their credentials or one-time passwords (OTPs) for 2FA authentication.
 - c) **Spearphishing via Service (T1566.003)**: TA use third-party channels, such as social media, to distribute malicious links or attachments.
 - d) **Spearphishing Voice (T1566.004)**: Attackers deceive victims via phone calls to obtain credentials or intrude into communications [35].
- 4) **Trusted Relationship (T1199)**: TA leverage the existing trust relationships among contacts of a compromised account, vendors, or clients to compromise other accounts through phishing attacks [31]. Additionally, if the compromised account has delegated permissions to other tenants, the attacker can access information from the other organization.
- 5) **Alternate Authentication Material (T1550)**: Attackers leverage alternative authentication methods to gain access to victim accounts. Sub-techniques include:
 - a) **Application Access Tokens (T1550.001) or Steal Application Access Token (T1528)**: Attackers exploit delegated permissions granted to applications using tokens to gain control of mailboxes [36].
 - b) **Web Session Cookie (T1550.004) or Steal Web Session Cookie (T1539)**: TA obtain session tokens or cookies through malware or malicious websites to gain control of user accounts [37], [38].
- 6) **Brute Force (T1110)**: TA conduct brute-force attacks to gain unauthorized access to accounts lacking

two-factor authentication (2FA) [39]. Sub-techniques include:

- a) **Password Guessing (T1110.001)**: Attackers attempt access using multiple passwords against a single account.
- b) **Password Spraying (T1110.003)**: Attackers use a list of passwords against multiple accounts.
- c) **Credential Stuffing (T1110.004)**: Attackers use leaked credentials for access attempts.

D. PERSISTENCE (TA0003)

Persistence involves the perpetrator's efforts to maintain access to the targeted email account for as long as possible, ensuring continued exploitation and deception. In addition to leveraging techniques used for initial access, TA employ various persistence techniques, including:

- 1) **Account Manipulation (T1098)**: TA manipulate compromised accounts to continue receiving pertinent emails even after losing direct access. Sub-techniques include:
 - a) **Email Forwarding Rule (T1114.003)**: By creating email forwarding rules within the victim's mailbox, TA redirect specific emails meeting predefined criteria to a controlled account [9], [15]. These rules may also conceal compromised communications.
 - b) **Additional Email Delegate Permissions (T1098.002)**: TA modify the permissions of folders in a victim's mailbox to make their contents readable by another user in the victim's tenant [40].
 - c) **Additional Cloud Roles (T1098.003)**: TA add additional roles or permissions to a compromised account, gaining administrative privileges, access to other accounts, or creating new accounts [41].
 - d) **Device Registration (T1098.005)**: TA configure new multifactor authentication mechanisms to log in without arousing suspicion [42].
- 2) **Alternate Authentication Material (T1550)**: To circumvent repeated login attempts using credentials, TA leverage alternative authentication methods, often capable of bypassing 2FA. Sub-techniques include:
 - a) **Application Access Tokens (T1550.001)**: Attackers utilize delegated permissions granted to applications via tokens to maintain control of compromised mailboxes [43].
 - b) **Web Session Cookie (T1550.004)**: TA leverage session cookies to sustain control of an account, avoiding the need for repeated credential-based logins [44].
- 3) **Modify Authentication Process (T1556)**: Attackers manipulate the authentication settings of a compromised account to ensure continued access and persistence. Sub-techniques include:

- a) **Multi-Factor Authentication (T1556.006)**: TA may disable or modify multifactor authentication to sustain persistence in the account [45], [46].
- 4) **Adversary-in-the-Middle (T1557)**: TA employ the Mail-In-The-Middle technique to maintain persistence by impersonating both parties in email communications, typically using counterfeit accounts created during the Resource Development phase. Sub-techniques include:
 - a) **Reply-To Field (T1557.XX)**: Attackers modify the “Reply-To” field in emails, redirecting replies to a different account under their control when recipients respond [6].
 - b) **Mail Thread Export (T1557.XX)**: TA export targeted email threads from the legitimate account and import them into a controlled mailbox, ensuring continued access to compromised communications [47], [48].

E. DEFENSE EVASION (TA0005)

Defense Evasion involves tactics aimed at circumventing detection and forensic investigation systems, enabling TA to maintain covert access and evade scrutiny. Within this tactic, TA employ various sub-techniques, including:

- 1) **Impersonation (T1656)**: Attackers impersonate the legitimate owners of compromised accounts to avoid detection and carry out fraud without raising suspicion [23].
- 2) **Indicator Removal (T1070)**: TA remove indicators of compromise from within the compromised mailbox. Sub-techniques include:
 - a) **Clear Mailbox Data (T1070.008)**: Attackers delete phishing emails, compromised threads, metadata, and other compromising data [49]. With administrative access, they may also delete existing logs to cover their tracks.
 - b) **Clear Persistence (T1070.009)**: Attackers eliminate persistence mechanisms such as configured 2FA devices or forwarding and mailbox rules within the compromised mailbox to avoid detection [50].
- 3) **Hide Artifacts (T1564)**: TA may undertake actions within the account to hide evidence of compromise or ongoing activities. Sub-techniques include:
 - a) **Email Hiding Rules (T1564.008)**: Attackers create rules within the mailbox to conceal responses to threads of interest or compromised threads by moving emails to a less common folder, preventing the legitimate user from identifying the fraud in a timely manner [50].
- 4) **Subvert Trust Controls (T1553)**: To evade email system protection mechanisms, TA employ techniques to obtain more trustworthy infrastructure [4], [5], [23], [51]. Sub-techniques include:

- a) **Trustful IP Provider (T1553.XX)**: TA utilize VPN services or hosting providers with IP addresses geolocated in reputable or trusted countries to avoid detection by SPAM filters or reputation-based blocking mechanisms used by mail service providers or infrastructure security teams. These IP addresses help attackers bypass initial scrutiny based on geographic or IP reputation.
- b) **Set Authentication Protocols (SPF, DKIM, DMARC) (T1553.XX)**: TAs configure SPF, DKIM, and DMARC authentication protocols on counterfeit domains they control. By properly setting up these protocols, they can make malicious emails appear legitimate, effectively bypassing the victim’s email security measures designed to detect spoofing or phishing attempts.
- c) **Trustful Mail Providers (T1553.XX)**: Attackers leverage reputable email providers with strong infrastructure, such as Gmail, Outlook, or Proton-Mail, to send malicious emails. By using these trusted services, they overcome victims’ protection measures, as emails from these providers are less likely to be flagged or blocked by security systems.

F. DISCOVERY (TA0007)

Discovery involves the process of identifying valuable accounts, such as administrative, executive, or financial department accounts, which could serve the attacker’s objectives. It also includes locating financial-related communications or files. This tactic includes the following techniques:

- 1) **Account Discovery (T1087)**: By leveraging available accesses and information contained within the compromised account and the organization’s configuration, attackers gather information about existing accounts. Sub-techniques include:
 - a) **Email Accounts (T1087.003)**: Attackers seek to obtain a list of email addresses present in the mailbox or contacts of the compromised account [25].
 - b) **Cloud Accounts (T1087.004)**: Attackers search for potentially relevant cloud service accounts associated with email that could be useful [52].
- 2) **Cloud Storage Object Discovery (T1619)**: Attackers search for documents stored in cloud services, such as OneDrive or Google Drive, to identify email accounts of interest [53].

G. PRIVILEGE ESCALATION (TA0004) / LATERAL MOVEMENT (TA0006) / CREDENTIAL ACCESS (TA0008)

Once target accounts within the infrastructure are identified, the Threat Actor (TA) may employ various techniques to obtain credentials, move laterally, and escalate privileges to

execute the fraud [6]. In the context of BEC frauds, the tactics of Credential Access (TA0008), Privilege Escalation (TA0004), and Lateral Movement (TA0006) are consolidated into a single phase, as the overarching goal is to gain access to an account with higher privileges or decision-making authority over financial transactions. While these tactics are clearly defined and distinct in other types of incidents, such as network intrusions or ransomware attacks, BEC frauds do not exhibit techniques that are exclusive to each of these phases. Instead, the techniques used during this stage are aligned toward the unified objective of gaining control over key accounts. Therefore, it is unnecessary to interpret these tactics independently, and only the techniques specific to this combined activity are presented below.

- 1) **Unsecured Credentials (T1552)**: Attackers search various sources for traces of shared credentials to gain access to other accounts. This technique includes the sub-technique:
 - a) **Chat Messages (T1552.008)**: TA may search for credentials shared in messaging chats accessible from the initially compromised account [41].
- 2) **Internal Spearphishing (T1534)**: TA can use compromised accounts to launch phishing attacks against other accounts within the domain, bypassing security mechanisms and exploiting the trust they engender [34].

H. COLLECTION (TA0009)

The Collection tactic involves gathering information of interest to be used in subsequent fraudulent activities by the threat actor. This tactic comprises the following techniques:

- 1) **Data from Cloud Storage (T1530)**: Attackers identify key documents such as invoices, orders, or bank payments in document repositories to orchestrate fraud schemes [53].
- 2) **Email Collection (T1114)**: This technique involves searching for email threads of interest that can be intercepted by the attacker. Sub-techniques include:
 - a) **Remote Email Collection (T1114.002)**: Attackers conduct keyword searches in the inbox or download entire mailboxes to collect crucial emails [53].
 - b) **Email Forwarding Rule (T1114.003)**: Attackers create forwarding rules that automatically redirect emails meeting specific criteria, such as keywords or specific recipients, enabling them to identify emails of interest for potential fraudulent activities [9].

I. EXFILTRATION (TA0010)

While not the primary objective of a BEC attacker, there is the possibility that the attacker may exfiltrate information for use in the specific fraud or for subsequent fraudulent activities [54]. This tactic comprises the following techniques:

- 1) **Exfiltration Over Web Service (T1567)**: The Threat Actor may utilize web access to directly download the

desired information present in the mailbox [53]. Sub-techniques include:

- a) **Exfiltration Over Webhook (T1567.004)**: Webhooks allow a server to push data over HTTP/S to a client without continuous polling by the client and can be exploited by attackers.
- 2) **Data from Cloud Storage (T1530)**: Attackers may exfiltrate data stored in the cloud for use in subsequent frauds or targeting other victims.
- 3) **Exfiltration Over Alternative Protocol (T1048)**: Various IaaS and SaaS platforms, such as Microsoft Exchange, Microsoft SharePoint, or Google Workspace, support direct downloading of files, emails, source code, and other sensitive information via the web console or Cloud API.

J. IMPACT (TA0040)

The Impact tactic represents the final step for the attacker, marking the culmination of the compromise. This tactic comprises the following techniques:

- 1) **Data Manipulation (T1565)**: Attackers manipulate information contained in emails or repositories, such as text or attachments, to divert payments in their favor. This technique includes the following sub-technique:
 - a) **Transmitted Data Manipulation (T1565.002)**: The attacker alters the information transmitted to another party in the transaction, usually modifying bank account numbers [23].
- 2) **Financial Theft (T1657)**: Attackers aim to orchestrate a financial transaction benefiting themselves, which may involve bank transfers or alternative methods such as gift cards [6].

V. DISCUSSION OF THE RESULTS

Following the described methodology, a total of 10 tactics, 34 techniques, and 46 sub-techniques were identified in the analysis of BEC frauds. These tactics and techniques were mapped to the MITRE ATT&CK framework, with careful attention to BEC-specific behaviors. Notably, 5 new sub-techniques were proposed as part of this research, filling gaps in the existing framework.

Among the newly proposed sub-techniques, two fall under the Persistence (TA0003) tactic and are associated with the Adversary-in-the-Middle (T1557) technique: **Reply-To Field (T1557.XX)** and **Mail Thread Export (T1557.XX)**. These techniques are specific to mailbox manipulation, a common practice among TA in BEC frauds. They allow attackers to intercept and control email communications, which is crucial for gaining access to sensitive information or tricking victims into fraudulent activities. These behaviors are not currently addressed by the MITRE ATT&CK framework and have thus been proposed as new sub-techniques. To mitigate the risk associated with the **Reply-To Field** manipulation, organizations can implement email security measures that trigger alerts when discrepancies are detected

Reconnaissance (TA0043)	Resource Development (TA0042)	Initial Access (TA0001)	Persistence (TA0003)	Defense Evasion (TA0005)	Discovery (TA0007)	Privilege Escalation (TA0004) / Lateral Movement (TA0006) / Credential Access (TA0008)	Collection (TA0009)	Exfiltration Over (TA0010)	Impact (TA0040)
Active Scanning (T1596)	Domain (T1583.001)	Exploit Public-Facing Mail Servers (T1196)	Email Forwarding Rule (T1144.003)	Impersonation (T1566)	Account Discovery (T1087)	Unsecured Credentials (T1552)	Out from Cloud Storage (T1530)	Exfiltration Over Webhook (T1567.004)	Data Manipulation (T1566)
Business Reconnaissance (T1593.002)	Server (T1583.004)	Valid Accounts (T1078)	Additional Email Permissions (T1096.002)	Clear Mailbox Data (T1070.008)	Cloud Accounts (T1087.004)	Cloud Messages (T1552.008)	Remote Email Collection (T1144.002)	Exfiltration Over Web Service (T1567)	Financial Theft (T1567)
Vulnerability Scanning (T1595.002)	Botnet (T1583.006)	Cloud Accounts (T1078.004)	Additional Cloud Roles (T1096.003)	Indicator Removal (T1079)	Cloud Storage (T1539)	Internal Sharing (T1534)	Email Forwarding Rule (T1144.003)	Exfiltration Over Network Protocol (T1568)	
Identity Roles (T1592.004)	Web Services (T1583.008)	Spamming Attachment (T1595.003)	Device Registration (T1070.009)	Hide Artifacts (T1564)					
Brute Force (T1110)	Acquire Access (T1584)	Spamming Link (T1595.002)	Application Access Tokens (T1550.001)	Trustful IP Provider (T1533.004)					
	Establish Accounts (T1585)	Phishing (T1586)	Alternate Authentication (T1550.004)	Subvert Trust Protocols (SPF, DKIM, DMARC) (T1553.XX)					
	Compromise Accounts (T1586)	Trusted Relationship (T1199)	Modify Process (T1556)	Trustful Mail Providers (T1553.XX)					
	Develop Capabilities (T1587)	Alternate Authentication Material (T1550)	Adversary In-Middle (T1557)						
	Stage Capabilities (T1588)	Web Session Cookie (T1550.001) / Shared Web Session Cookie (T1539)	Mail Thread Export (T1557.XX)						
		Link Target (T1608.006)							
		Brute Force (T1110)	Brute Force (T1110)						
			Credential Stuffing (T1133.004)						

FIGURE 2. BEC TTPs MITRE ATT&CK matrix.

between the “From” and “Reply-To” fields in an email. This simple rule can help detect fraudulent emails where attackers attempt to reroute communications without raising suspicion. Additionally, organizations can implement advanced email authentication mechanisms and conduct regular training for employees to recognize such threats.

The remaining three sub-techniques are part of the Defense Evasion (T1553) tactic and the Subvert Trust Controls (T1553) technique: **Trustful IP Provider (T1553.XX)**, **Set Authentication Protocols (SPF, DKIM, DMARC) (T1553.XX)**, and **Trustful Mail Providers (T1553.XX)**. These sub-techniques are specific to email-based attacks and are designed to bypass security defenses within the victim’s infrastructure, enabling the delivery of malicious emails to the target’s mailbox without detection. By using trusted IP addresses and manipulating email authentication protocols, attackers can evade common filtering systems, making these techniques crucial for understanding and mitigating BEC incidents. However, mitigating these techniques presents a significant challenge, as they rely on legitimate email security mechanisms that are widely used to ensure deliverability and authenticity.

Additionally, three original MITRE tactics—**Privilege Escalation (TA0004)**, **Lateral Movement (TA0006)**, and **Credential Access (TA0008)**—were merged into a single attack phase. This decision was based on the fact that these tactics share the same overall goal: gaining access to accounts with higher privileges or decision-making authority within the organization. Furthermore, the techniques and sub-techniques used by attackers in these phases are identical. Although a new name could have been proposed for this merged phase, the authors opted to retain the existing MITRE framework nomenclature for consistency and clarity.

In this study, the **Execution (TA0002)** tactic was deliberately omitted from the proposed framework, as its relevance to BEC frauds is minimal compared to other tactics. Unlike other forms of cyberattacks such as ransomware or data exfiltration, where the execution of malicious code plays a pivotal role, BEC frauds predominantly rely on social engineering, email manipulation, and credential abuse. These attacks do not typically involve the execution of code on the victim’s infrastructure, as their success depends more on exploiting trust relationships and legitimate communication channels than on the deployment of malware. The decision to exclude the *Execution* tactic was based on the data sets reviewed and the characteristics of known BEC TA whose methodologies do not feature the use of malicious execution. However, it is acknowledged that certain BEC scenarios might involve the indirect use of malware (e.g., stealers for credential harvesting). In these cases, malware execution is better categorized under techniques like **Initial Access (TA0001)** or **Credential Access (TA0008)**, as it primarily serves preparatory or auxiliary purposes rather than forming a core component of the BEC lifecycle.

Furthermore, some sub-techniques were added under techniques not originally contemplated in the MITRE ATT&CK framework, meaning that they do not match the parent codes of the existing techniques. This adjustment was made because, in BEC attacks, these sub-techniques can be more practically associated with a different technique. It was therefore more efficient to reference an existing

sub-technique than to propose a redundant creation of a new sub-technique with the same definition.

The following subsections have been included to demonstrate the practical application of the final matrix developed in this study. By testing its usage on two distinct BEC threat actors, Cosmic Lynx and Chiffon Herring, we aim to validate the matrix's adaptability and effectiveness in characterizing attackers with varying levels of sophistication and operational goals. These case studies provide insights into how the matrix can standardize the representation of TTPs, facilitate incident attribution, and guide the development of targeted defensive measures. Each subsection highlights the unique characteristics and strategies of the selected threat actors, showcasing the versatility of the proposed framework in addressing diverse BEC scenarios.

A. CASE STUDY: APPLYING THE FRAMEWORK TO CHARACTERIZE COSMIC LYNX

In this subsection, we demonstrate an example of applying the matrix developed from our research to characterize a real-world TA. Cosmic Lynx, a Russian-based cybercriminal group, provides a relevant case for this analysis. Operating since 2019, Cosmic Lynx has been notable for its highly sophisticated BEC operations, targeting multinational organizations and high-level executives involved in financial decisions. The following characterization is based on insights from Agari Data, Inc. [55], Robert Scammell [56], and Lindsey O'Donnell [57].

The characterization was achieved by extracting the TTPs of Cosmic Lynx from CTI reports and mapping them into the matrix developed through our research. This mapping provides a structured framework for attributing incidents to specific TAs and aids in the analysis of their operational methods. By systematically aligning Cosmic Lynx's observed behaviors with our framework, we demonstrate how this approach enhances the attribution process, guides incident analysis, and supports the development of mitigation strategies.

Cosmic Lynx's TTPs align closely with the MITRE ATT&CK framework, specifically as adapted for BEC frauds as a result of this research. Below, we map their observed TTPs to our framework, illustrating the group's comprehensive approach across several phases. A graphical representation of this characterization, with identified techniques and sub-techniques highlighted in green, can be seen in Figure 3, which can be found at the end of this section.

1) Reconnaissance (TA0043):

- a) **Victim Organization Information (T1591):**
 - i) **Business Relationships (T1591.002) and Identify Roles (T1591.004):** Cosmic Lynx performs targeted reconnaissance to understand the business relationships and key personnel within target organizations, particularly identifying individuals with financial authority.

2) Resource Development (TA0042):

- a) **Acquire Infrastructure (T1583):**
 - i) **Domain (T1583.001), Server (T1583.004), and Web Services (T1583.006):** The group registers domains and configures servers to mimic secure email systems, such as "secure-mail-gateway[.]cc," establishing trust for future communications.
- b) **Acquire Access (T1650):** TA may acquire compromised accounts from IAB to gain unauthorized entry into the victim's infrastructure.
- c) **Establish Accounts (T1585):** They create and maintain fake email accounts, representing high-ranking corporate figures to facilitate impersonation in their phishing campaigns.
- d) **Compromise Accounts (T1586) and Email Accounts (T1586.002):** Compromised email accounts are used to further reinforce the legitimacy of their interactions with targeted victims.
- e) **Develop Capabilities (T1587) and Malware (T1587.001):** Cosmic Lynx embedded malware in phishing emails sent from compromised accounts to infiltrate and infect the victim's network.

3) Initial Access (TA0001):

- a) **Valid Accounts (T1078):**
 - i) **Domain Accounts (T1078.002) and Cloud Accounts (T1078.004):** Access to both domain and cloud accounts is obtained through phishing, enabling the group to infiltrate internal communications.
- b) **Phishing (T1566):**
 - i) **Spearphishing Attachment (T1566.001) and Spearphishing Link (T1566.002):** Customized phishing emails include attachments or links that align with the victim's business operations, such as merger and acquisition scenarios.
- c) **Trusted Relationship (T1199):** By impersonating trusted executives and legal representatives, Cosmic Lynx leverages established trust relationships to manipulate victims effectively.

4) Persistence (TA0003):

- a) **Adversary-in-the-Middle (T1557):**
 - i) **Reply-To Field (T1557.XX):** The group modifies the "Reply-To" field in emails to redirect responses to their own infrastructure, bypassing genuine executives.

5) Defense Evasion (TA0005):

- a) **Impersonation (T1656):** Cosmic Lynx impersonates trusted entities, such as high-ranking executives or legal representatives, to build

- i) **Trustful IP Provider (T1553.XX), Set Authentication Protocols (SPF, DKIM, DMARC) (T1553.XX), and Trustful Mail Providers (T1553.XX):** Cosmic Lynx leverages trusted IP addresses or mail service providers and configures DMARC protocol on their spoofed domains to bypass email filtering and avoid detection by spam filters.

- i) **Email Accounts (T1087.003):** Once inside the network, the group investigates email account structures to identify key communication flows and financial personnel, ensuring timely interception of transactions.

a) **Data Manipulation (T1565.002) and Financial Theft (T1657):** The group manipulates invoice details, altering payment instructions to divert funds to mule accounts located in jurisdictions less likely to arouse suspicion, such as Hong Kong.

The characterization was achieved by extracting the TTPs of Chiffon Herring from CTI reports and mapping them into the matrix developed through our research. This mapping highlights the utility of the proposed techniques, including the newly introduced sub-techniques such as “Reply-To Field (T1557.XX)” and those under “Subvert Trust Controls (T1553).” These sub-techniques are critical for understanding how attackers impersonate legitimate communications without triggering alerts and establish persistence within

[illegible]

email threat communications. In the following, we map the observed TTPs of Chiffon Herring to our framework, demonstrating their approach in multiple attack phases, with a graphical representation provided in Figure 4, appearing towards the end of this section.

of incidents and enables researchers to correlate TTP matrices across different groups, potentially uncovering connections between TAs operating under different given names by researchers. Conversely, the characterization of Chiffon Herring, a smaller-scale TA focused on simpler schemes such as payroll diversion, highlights the matrix's versatility in guiding investigations of less sophisticated but equally impactful threats. Understanding the specific techniques employed by both TAs allows organizations to prioritize defensive measures, such as implementing targeted monitoring and applying preventative actions tailored to the scale and objectives of the adversary. These case studies demonstrate how the matrix not only enhances the organization and analysis of diverse threat behaviors but also serves as a practical tool for proactive defense strategies across a spectrum of adversaries.

VI. CONCLUSION AND FUTURE WORK

This research has successfully met its objectives by identifying and categorizing the diverse techniques employed by Threat Actors (TAs) in Business Email Compromise (BEC) frauds. By systematically applying the MITRE ATT&CK framework, we identified a total of 12 tactics, with **Privilege Escalation (TA0004)**, **Lateral Movement (TA0006)**, and **Credential Access (TA0008)** merged into a single attack phase due to overlapping objectives and techniques, and **Execution (TA0002)** excluded as it was not applicable to the typical BEC attack lifecycle. The analysis also resulted in the identification of 34 techniques and 46 sub-techniques, including the proposal of five new sub-techniques—*Reply-To Field (T1557.XX)*, *Mail Thread Export (T1557.XX)*, *Trustful IP Provider (T1553.XX)*, *Set Authentication Protocols (SPF, DKIM, DMARC) (T1553.XX)*, and *Trustful Mail Providers (T1553.XX)*—to address existing gaps in the framework, particularly in the areas of Adversary-in-the-Middle and Defense Evasion.

The categorization developed in this study offers a comprehensive framework that enables CTI researchers to accurately characterize BEC attackers. This facilitates incident attribution, enhances investigative capabilities, and aids in developing more effective mitigation and prevention strategies. Moreover, applying these tactics and techniques can yield valuable statistics in the future, providing insights into emerging attacker behaviors and techniques.

The case studies of Cosmic Lynx and Chiffon Herring further validate the utility of this framework. By successfully applying the proposed TTP matrix to characterize both a sophisticated TA like Cosmic Lynx and a smaller-scale actor like Chiffon Herring, the study confirms that the framework can serve as a critical tool for researchers in analyzing and attributing BEC attacks. For Cosmic Lynx, the framework facilitates the investigation of complex and organized operations targeting high-value victims, while for Chiffon Herring, it demonstrates its applicability to simpler schemes that still exploit trust and evade detection. These applications enhance the efficiency of investigations by

guiding the analysis process, supporting efforts to mitigate the threat, and prioritizing defensive actions tailored to the specific techniques and scale of the adversary. This practical validation highlights the adaptability and relevance of the framework in real-world scenarios, as well as its potential for standardizing characterization efforts in both academic and CTI contexts.

Looking ahead, this framework will be crucial for the ongoing characterization of TAs and the continuous improvement of cybersecurity strategies. Future work will involve updating the framework with newly identified techniques and tactics as they emerge. This dynamic approach will ensure that cybersecurity defenses remain robust and adaptive to the evolving landscape of BEC frauds. By continually refining this framework, we aim to provide a resilient tool for the cybersecurity community, enhancing its ability to combat BEC frauds and protect organizational assets.

Another promising avenue for future research will involve applying the proposed TTP matrix to the specific modus operandi of known BEC TAs. This approach will help identify potential connections between TAs who may be classified under different names but are, in fact, the same group. By leveraging this matrix, researchers can contribute to more accurate tracking and disruption of BEC campaigns, ultimately strengthening global defenses against these evolving cyber threats.

Additionally, given the limited availability of open datasets or large-scale reports on BEC fraud incidents, future research will focus on testing the matrix in other organizational databases. Expanding the validation process across multiple datasets will enhance the framework's generalizability and ensure its applicability in diverse operational environments.

ACKNOWLEDGMENT

The authors would like to extend their heartfelt thanks to their colleagues with the Department of Telematics Engineering, Polytechnic University of Catalonia (ENTEL-UPC) for their invaluable support and assistance throughout the course of this research. Their expertise and collaborative spirit have been instrumental in shaping the direction and quality of this work. They also express their sincere gratitude to INCIDE Digital Data S.L. for their technical support. Their contributions have been crucial in enabling them to pursue and realize their research objectives.

REFERENCES

- [1] T. M. Corp. *Mitre ATT&CK*. Accessed: Feb. 20, 2024. [Online]. Available: <https://attack.mitre.org>
- [2] T. M. Corp. (2015). *Mitre ATT&CK Matrix-enterprise*. Accessed: Feb. 20, 2024. [Online]. Available: <https://attack.mitre.org/matrices/enterprise/>
- [3] S. Mansfield-Devine, "The imitation game: How business email compromise scams are robbing organisations," *Comput. Fraud Secur.*, vol. 2016, no. 11, pp. 5–10, Nov. 2016.
- [4] APWG. (2024). *Phishing Activity Trends Report 3rd Quarter 2024*. Accessed: Jan. 25, 2025. [Online]. Available: <https://apwg.org/trendsreports/>
- [5] F. B. of Investigation (FBI). *2023 Internet Crime Report*. Accessed: Jan. 25, 2023. [Online]. Available: <https://www.ic3.gov/Media/PDF/AnnualReport/2022IC3Report.pdf>

- [6] N. Saud Al-Musib, F. Mohammad Al-Serhani, M. Humayun, and N. Z. Jhanjhi, "Business email compromise (BEC) attacks," *Mater. Today, Proc.*, vol. 81, pp. 497–503, Jan. 2023.
- [7] A. Binks, "The art of phishing: Past, present and future," *Comput. Fraud Secur.*, vol. 2019, no. 4, pp. 9–11, Apr. 2019.
- [8] Tessian, "Tessian: Spear-phishing threat landscape 2021," *Comput. Fraud Secur.*, vol. 2021, no. 10, p. 4, Oct. 2021.
- [9] A. Meyers, "Not your fairy-tale prince: The Nigerian business email compromise threat," *Comput. Fraud Secur.*, vol. 2018, no. 8, pp. 14–16, Jan. 2018.
- [10] S. C. Sethuraman, D. P. V. T. Reddi, M. S. T. Reddy, and M. K. Khan, "A comprehensive examination of email spoofing: Issues and prospects for email security," *Comput. Secur.*, vol. 137, Feb. 2024, Art. no. 103600.
- [11] M. Jakobsson, *Understanding Social Engineering Based Scams*, vol. 233. Cham, Switzerland: Springer, 2016.
- [12] S. Mansfield-Devine, "Bad behaviour: Exploiting human weaknesses," *Comput. Fraud Secur.*, vol. 2017, no. 1, pp. 17–20, Jan. 2017.
- [13] J. M. Esparza, "Understanding the credential theft lifecycle," *Comput. Fraud Secur.*, vol. 2019, no. 2, pp. 6–9, Jan. 2019.
- [14] J. Buckley, "The industrialisation of cyber extortion," *Comput. Fraud Secur.*, vol. 2021, no. 12, pp. 6–10, Dec. 2021.
- [15] A. Papathanasiou, G. Lontos, V. Liagkou, and E. Glavas, "Business email compromise (BEC) attacks: Threats, vulnerabilities and countermeasures—A perspective on the Greek landscape," *J. Cybersec. Privacy*, vol. 3, no. 3, pp. 610–637, Sep. 2023.
- [16] O. Ogwo-Ude, "Business email compromise challenges to medium and large-scale firms in USA: An analysis," *Open J. Appl. Sci.*, vol. 13, no. 6, pp. 803–812, 2023.
- [17] A. Raj, V. Narayan, V. Muskan, A. Sani, P. Sharma, and S. S. Sarma, "Modern ransomware: Evolution, methodology, attack model, prevention and mitigation using multi-tiered approach," *Secur. Privacy*, vol. 7, no. 6, p. e436, Jun. 2024.
- [18] M. Mundt and H. Baier, "Towards mitigation of data exfiltration techniques using the mitre att&ck framework," in *Proc. Int. Conf. Digit. Forensics Cyber Crime*, Cham, Switzerland: Springer, 2021, pp. 139–158.
- [19] A. B. Izzuddin and C. Lim, "Mapping threats in smart grid system using the MITRE ATT&CK ICS framework," in *Proc. IEEE Int. Conf. Aerosp. Electron. Remote Sens. Technol. (ICARES)*, Nov. 2022, pp. 1–7.
- [20] L. Fortra, "Russians get into the BEC game," *Comput. Fraud Secur.*, vol. 2020, no. 7, p. 3, Jul. 2020.
- [21] F. FKIE. (2021). *GOLD SKYLINE (Threat Actor)*. Accessed: Feb. 20, 2024. [Online]. Available: <https://malpedia.caad.fkie.fraunhofer.de/actor/goldskyline>
- [22] T. Micro. *GOLD GALLEON Targets Maritime Shipping Companies' Customers in BEC Campaigns*. Accessed: Feb. 20, 2024. [Online]. Available: <https://www.trendmicro.com/vinfo/it/security/news/cybercrime-and-digital-threats/gold-galleon-targets-maritime-shipping-companies-customers-in-bec-campaigns>
- [23] N. T. Nisha, D. Bakari, and C. Shukla, "Business e-mail compromise—techniques and countermeasures," in *Proc. Int. Conf. Adv. Comput. Innov. Technol. Eng. (ICACITE)*, Mar. 2021, pp. 217–222.
- [24] J. Kolouch, "Evolution of phishing and business email compromise campaigns in the Czech republic," *Academic Appl. Res. Mil. Public Manage. Sci.*, vol. 17, no. 3, pp. 83–100, Dec. 2018.
- [25] D. Zweighaft, "Business email compromise and executive impersonation: Are financial institutions exposed?" *J. Investment Compliance*, vol. 18, no. 1, pp. 1–7, May 2017.
- [26] T. Yadav and R. A. Mallari, "Technical aspects of cyber kill chain," in *Proc. Int. Symp. Secur. Comput. Commun.*, Kochi, India: Cham, Switzerland: Springer, Aug. 2015, pp. 438–452.
- [27] S. Caltagirone, A. Pendergast, and C. Betz, "The diamond model of intrusion analysis," *Threat Connect*, vol. 298, pp. 1–61, Jul. 2013.
- [28] N. Naik, P. Jenkins, P. Grace, and J. Song, "Comparing attack models for it systems: Lockheed Martin's cyber kill chain, mitre att&ck framework and diamond model," in *Proc. IEEE Int. Symp. Syst. Eng. (ISSE)*, Oct. 2022, pp. 1–7.
- [29] (2015). *Incide | Ciberseguridad-DFIR-Auditora-Red Team-incide*. Accessed: Feb. 20, 2024. [Online]. Available: <https://www.incide.es/>
- [30] D. Wilusz, D. Sadowczyk, A. Wójciewicz, and L. Tasiemski, "Long tail of security vulnerabilities and nation state apt actors," *Proc. Book*, vol. 25, no. 26, p. 3, 2022.
- [31] K. Chetoui, B. Bah, A. O. Alami, and A. Bahasse, "Overview of social engineering attacks on social networks," *Proc. Comput. Sci.*, vol. 198, pp. 656–661, Jan. 2022.
- [32] R. Almeida and C. Westphall, "Heuristic phishing detection and URL checking methodology based on scraping and web crawling," in *Proc. IEEE Int. Conf. Intell. Secur. Inform. (ISI)*, Nov. 2020, pp. 1–6.
- [33] M. Bossetta, "The weaponization of social media: Spear phishing and cyberattacks on democracy," *J. Int. Affairs*, vol. 71, nos. 1–5, pp. 97–106, 2018.
- [34] G. Ho, A. Cidon, L. Gavish, M. Schweighauser, V. Paxson, S. Savage, G. M. Voelker, and D. Wagner, "Detecting and characterizing lateral phishing at scale," in *Proc. 28th USENIX Secur. Symp. (USENIX Secur.)*, Aug. 2019, pp. 1273–1290.
- [35] A. De Rancourt-Raymond and N. Smaili, "The unethical use of deepfakes," *J. Financial Crime*, vol. 30, no. 4, pp. 1066–1077, May 2023.
- [36] R. A. Grimes, "Access control token tricks," in *Hacking Multifactor Authentication*. Wiley Data and Cybersecurity, 2021, pp. 141–161.
- [37] Y. B. Choi, Y. L. Loo, and K. LaCroix, "Cookies and sessions: A study of what they are, how they can be stolen and a discussion on security," *Int. J. Adv. Comput. Sci. Appl.*, vol. 10, no. 1, pp. 1–5, 2019.
- [38] H. Kwon, H. Nam, S. Lee, C. Hahn, and J. Hur, "(In-)security of cookies in HTTPS: Cookie theft by removing cookie flags," *IEEE Trans. Inf. Forensics Security*, vol. 15, pp. 1204–1215, 2020.
- [39] X. Liu and X. Hu, "Research on techniques for detecting brute-force attacks on corporate email," *J. Comput. Methods Sci. Eng.*, vol. 24, no. 3, pp. 1379–1393, Jun. 2024.
- [40] Mandiant. *Remediation and Hardening Strategies for Microsoft 365 to Defend Against UNC2452 | Blog | Mandiant-Mandiant*. Accessed: Feb. 22, 2024. [Online]. Available: <https://www.mandiant.com/resources/blog/remediation-and-hardening-strategies-for-microsoft-365-to-defend-against-unc2452>
- [41] Microsoft Incident Response. (2022). *DEV-0537 Criminal Actor Targeting Organizations for Data Exfiltration and Destruction | Microsoft Security Blog*. Accessed: Feb. 22, 2024. [Online]. Available: <https://www.microsoft.com/en-us/security/blog/2022/03/22/dev-0537-criminal-actor-targeting-organizations-for-data-exfiltration-and-destruction/>
- [42] M. T. Intell. (2022). *Evolved Phishing: Device Registration Trick Adds to Phishers' Toolbox for Victims Without MFA | Microsoft Security Blog*. Accessed: Feb. 22, 2024. [Online]. Available: <https://www.microsoft.com/en-us/security/blog/2022/01/26/evolved-phishing-device-registration-trick-adds-to-phishers-toolbox-for-victims-without-mfa/>
- [43] E. Stalmans. (2017). *Phishing With OAuth and O365/Azure*. Accessed: Feb. 22, 2024. [Online]. Available: <https://staaldrad.github.io/2017/08/02/o365-phishing-with-oauth/>
- [44] W. H. Yue Chen, Cong Zheng and Z. Xu. (2019). *Mac Malware Steals Cryptocurrency Exchanges Cookies*. Accessed: Feb. 21, 2024. [Online]. Available: <https://unit42.paloaltonetworks.com/mac-malware-steals-cryptocurrency-exchanges-cookies/>
- [45] CISA. (2022). *Russian State-Sponsored Cyber Actors Gain Network Access by Exploiting Default Multifactor Authentication Protocols and PrintNightmare Vulnerability | CISA*. Accessed: Feb. 22, 2024. [Online]. Available: <https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-074a>
- [46] S. Amft, S. Höltervenhoff, N. Huaman, A. Krause, L. Simko, Y. Acar, and S. Fahl, "We've disabled mfa for you': An evaluation of the security and usability of multi-factor authentication recovery deployments," in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur.*, 2023, pp. 3138–3152.
- [47] jukelenings. (2023). *SaaS-Attacks/Techniques/Webhooks/Description*. Accessed: Feb. 22, 2024. [Online]. Available: <https://github.com/pushsecurity/saas-attacks/blob/main/techniques/webhooks/description.md>
- [48] H. F. Atlam and O. Oluwatimilehin, "Business email compromise phishing detection based on machine learning: A systematic literature review," *Electronics*, vol. 12, no. 1, p. 42, Dec. 2022.
- [49] A. Dahan. (2017). *Operation Cobalt Kitty*. Accessed: Feb. 22, 2024. [Online]. Available: <https://cdn2.hubspot.net/hubfs/3354902/Cybereason Labs Analysis Operation Cobalt Kitty.pdf>
- [50] M. T. Intell. (2022). *Malicious OAuth Applications Abuse Cloud Email Services to Spread Spam | Microsoft Security Blog*. Accessed: Feb. 22, 2024. [Online]. Available: <https://www.microsoft.com/en-us/security/blog/2022/09/22/malicious-oauth-applications-used-to-compromise-email-servers-and-spread-spam/>

- [51] H. Siadati, T. Nguyen, and N. Memon, "X-platform phishing: Abusing trust for targeted attacks short paper," in *Proc. Int. Conf. Financial Cryptogr. Data Secur.*, Sliema, Malta. Cham, Switzerland: Springer, Apr. 2017, pp. 587–596.
- [52] M. T. Intell. (2021). *NOBELIUM Targeting Delegated Administrative Privileges to Facilitate Broader Attacks* | *Microsoft Security Blog*. Accessed: Feb. 22, 2024. [Online]. Available: <https://www.microsoft.com/en-us/security/blog/2021/10/25/nobelium-targeting-delegated-administrative-privileges-to-facilitate-broader-attacks/>
- [53] D. A. Haddon, "Attack vectors and the challenge of preventing data theft," in *Cyber Security Practitioner's Guide*. Singapore: World Scientific, 2020, pp. 1–50.
- [54] S. Wassermann, M. Meyer, S. Goutal, and D. Riquet, "Targeted attacks: Redefining spear phishing and business email compromise," 2023, *arXiv:2309.14166*.
- [55] I. Agari Data, "Cosmic lynx the rise of Russian BEC," Agari Data, Eden Prairie, MN, USA, Tech. Rep., 2022. [Online]. Available: <https://static.fortra.com/agari/pdfs/guide/ag-acid-cosmic-lynx-gd.pdf>
- [56] V. E. Team. (2020). *Cosmic Lynx, Russian BEC Group*. Accessed: Nov. 10, 2024. [Online]. Available: <https://www.verdict.co.uk/cosmic-lynx-russian-bec/>
- [57] T. E. Team. (2020). *Russian BEC Gang Cosmic Lynx Uncovered*. Accessed: Nov. 10, 2024. [Online]. Available: <https://threatpost.com/russian-bec-gang-cosmic-lynx-uncovered/157166/>
- [58] A. S. Intell. (2023). *Bec Group Targets Payroll Diversion Attacks*. Accessed: Jan. 26, 2025. [Online]. Available: <https://intelligence.abnormalsecurity.com/blog/bec-group-targets-teachers-payroll-diversion-attacks>



SEBASTIEN KANJ BONHARD received the degree in telecommunications engineering from the Escola Tècnica Superior d'Enginyeria de Telecomunicació de Barcelona (ETSEB), in 2021. He is currently pursuing the Industrial Ph.D. degree with the Information Security Group (ISG-MAK), UPC, in collaboration with INCIDE Digital Data S.L., as part of the Industrial Ph.D. Program of the Generalitat of Catalunya.

While completing his studies, he began working as an Incident Handler with INCIDE Digital Data S.L., a Spanish cybersecurity company. He has participated in over 100 ransomware incidents and more than 50 BEC fraud investigations, gaining deep insights into threat actor methodologies. He has co-authored three articles presented at national and international conferences and lectures in the Master's Degree in Cybersecurity Program, UPC. He has also delivered presentations at international private cybersecurity conferences. His research interests include digital forensics, incident response, and the characterization of threat actors.



PAU GARCIA VILLALTA received the degree in physics from the University of Barcelona (UB).

He joined INCIDE Digital Data S.L., in 2019, as a Digital Forensics and Incident Response (DFIR) Analyst. Since then, he has contributed to the resolution of numerous data breaches, business email compromise (BEC) frauds, and other cybersecurity incidents. His professional focus lies in digital forensics, incident handling, and proactive threat hunting to strengthen organizational security.



ORIO ROSÉS received the master's degree in telecommunications engineering from the Universitat Politècnica de Catalunya (UPC), in 1998, the master's degree in information security technologies from esCERT-UPC/TB-Security, in 2008, and the master's degree in cybercrime from the International University of Catalonia.

He also holds a European Certificate in cybercrime and electronic evidence from European Commission and Cybex. He specializes in operations management, project and incident coordination, and electronic evidence expertise. With over 15 years of experience, he has directed and managed more than 1000 DFIR projects. He has extensive teaching experience, including roles as a Professor in the Digital Law Master's Program, IL3—University of Barcelona. He has delivered multiple lectures and training sessions for BAR associations, private clients, and public forums. His research interests include digital forensics, incident response, and the practical application of cybersecurity measures.



JOSEP PEGUEROLS (Member, IEEE) received the degree in telecommunications engineering from the Escola Tècnica Superior d'Enginyeria de Telecomunicació de Barcelona (ETSEB), in 1997, and the Ph.D. degree, in 2003, focusing on cryptographic key management protocols in multicast networks.

His postdoctoral research expanded into electronic payments, security in multimedia and mobile communications, and medical data sharing.

He was the Director of ETSETB-UPC, from 2019 to 2023, and has maintained strong international collaborations with research teams across Europe. As a principal investigator, he has led national and international research and development projects, including the ViCOMO and WebofObjects Projects under ITEA2 and the National TAMESIS Project. He has authored 23 articles in ISI-JCR-indexed journals, four book chapters, and numerous conference papers. In addition to his academic work, he is a certified digital forensic expert and has conducted dozens of expert reports and cybersecurity audits. He has supervised four completed Ph.D. theses and currently co-supervises two more on cyberattack prevention in hospital environments.

...